



1. SOC Fundamentals and Operations :

Tier 1 (L1 SOC Analyst)

Responsibility:

- Handle the flood of alerts and make fast decisions.

What they actually do:

- Monitor SIEM dashboards
- Triage alerts (false positive vs suspicious)
- Collect basic evidence (logs, IPs, users)
- Escalate real threats to Tier 2

Reality check:

If they're slow or clueless, everything downstream breaks.

Tier 2 (L2 SOC Analyst)

Responsibility:

Figure out what's really happening.



What they actually do:

- Deep investigation of escalated alerts.
- Correlate logs across systems.
- Identify attack type, entry point, and spread.
- Recommend containment actions.

Reality check:

If they miss something, attackers stay inside longer.

Tier 3 (Threat Hunter / Senior Analyst)

Responsibility:

- Find threats before alerts even exist.
- What they actually do:
- Hunt for hidden attacker behavior
- Build detection rules/use cases
- Analyze advanced attack techniques
- Improve SOC detection capability

Reality check:

Without them, your SOC is always reactive.



SOC Manager:

Responsibility:

- Make sure the SOC actually works under pressure.

What they actually do:

- Manage team workload and shifts
- Define alert priorities and SLAs
- Reduce alert fatigue
- Coordinate incident response at a high level

Reality check:

- Bad manager = chaos, burnout, missed attacks.

MITRE ATT&CK :

MITRE ATT&CK is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.



MITRE | ATT&CK

Matrices | Tactics | Techniques | Defenses | CTI | Resources | Benefactors | Contribute | Blog | Search Q

ATT&CK Matrix for Enterprise

layout: side | show sub-techniques | hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (13)	BITS Jobs	Access Token Manipulation (3)	Access Token Manipulation (3)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Build Image on Host	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture
Gather Victim Network Information (8)	Compromise Infrastructure (6)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (3)	Boot or Logon Autostart Execution (14)	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts (3)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Browser Session Hijacking
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Exploitation for Client Execution	Compromise Host Software Binary	Create or Modify System Process (3)	Deploy Container	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data
Search Closed Sources (2)	Obtain Capabilities (7)	Replication Through Removable Media	Input Injection	Create Account (3)	Domain or Tenant Policy Modification (2)	Direct Volume Access	Input Capture (4)	Cloud Storage Object Discovery	Data from Cloud Storage	Data from Cloud Storage
Search Open Technical Databases (5)	Stage Capabilities (6)	Supply Chain Compromise (3)	Inter-Process Communication (3)	Create or Modify System Process (3)	Escape to Host	Domain or Tenant Policy Modification (2)	Modify Authentication Process (9)	Container and Resource Discovery	Software Deployment Tools	Data from Configuration Repository (2)
Search Open Websites/Domains (3)		Trusted Relationship	Native API	Create or Modify System Process (3)	Event Triggered Execution (18)	Email Spoofing	Multi-Factor Authentication Interception	Debugger Evasion	Taint Shared Content	Data from Information Repositories (8)
Search Threat Vendor Data			Poisoned Pipeline Execution	Event Triggered Execution (18)	Event Triggered	Exploitation for		Device Driver Discovery		Data from

MITRE | ATT&CK

Matrices | Tactics | Techniques | Defenses | CTI | Resources | Benefactors | Contribute | Blog | Search Q

TECHNIQUES

Reconnaissance

Active Scanning

Scanning IP Blocks

Vulnerability Scanning

Wordlist Scanning

Gather Victim Host Information

Gather Victim Identity Information

Gather Victim Network Information

Gather Victim Org Information

Phishing for Information

Search Closed Sources

Search Open

Sub-techniques (3)

ID	Name
T1595.001	Scanning IP Blocks
T1595.002	Vulnerability Scanning
T1595.003	Wordlist Scanning

Adversaries may execute active reconnaissance scans to gather information that can be used during targeting. Active scans are those where the adversary probes victim infrastructure via network traffic, as opposed to other forms of reconnaissance that do not involve direct interaction.

Adversaries may perform different forms of active scanning depending on what information they seek to gather. These scans can also be performed in various ways, including using native features of network protocols such as ICMP.^{[1][2]} Information from these scans may reveal opportunities for other forms of reconnaissance (ex: Search Open Websites/Domains or Search Open Technical Databases), establishing operational resources (ex: Develop Capabilities or Obtain Capabilities), and/or initial access (ex: External Remote Services or Exploit Public-Facing Application).

Procedure Examples

ID	Name	Description
----	------	-------------

ID: T1595

Sub-techniques: T1595.001, T1595.002, T1595.003

Tactic: Reconnaissance

Platforms: PRE

Version: 1.0

Created: 02 October 2020

Last Modified: 24 October 2025

Version Permalink

NIST Cybersecurity Framework:

The CSF is designed to be used by organizations of all sizes and sectors, including industry, government, academia, and nonprofit organizations, regardless of the maturity level of their cybersecurity programs.

The CSF is a foundational resource that may be adopted voluntarily and through governmental policies and mandates.



The CSF's taxonomy and referenced standards, guidelines, and practices are not country-specific, and previous versions of the CSF have been leveraged successfully by many governments and other organizations both inside and outside of the United States.

The CSF should be used in conjunction with other resources (e.g., frameworks, standards, guidelines, leading practices) to better manage cybersecurity risks and inform the overall management of information and communications technology (ICT) risks at an enterprise level.

The CSF is a flexible framework that is intended to be tailored for use by all organizations regardless of size. Organizations will continue to have unique risks — including different threats and vulnerabilities — and risk tolerances, as well as unique mission objectives and requirements. Thus, organizations' approaches to managing risks and their implementations of the CSF will vary.

 NIST The NIST Cybersecurity Framework 2.0 www.nist.gov/cyberframework NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY U.S. DEPARTMENT OF COMMERCE				
Function	Category	Subcategory	Implementation Examples	Informative References
IDENTIFY (ID): The organization's current cybersecurity risks are understood				CRI Profile v2.0: ID CSF v1.1: ID ISO/IEC 27001:2022: Mandatory Clause: 8.1 ISO/IEC 27001:2022: Mandatory Clause: 8.2 ISO/IEC 27001:2022: Mandatory Clause: 8.3 ISO/IEC 27001:2022: Mandatory Clause: 10.2 ISO/IEC 27001:2022: Annex A Controls: None SCF: RSK-01 SCF: RSK-01.1 SCF: RSK-04 SCF: RSK-09
	Asset Management (ID.AM): Assets (e.g., data, hardware, software, systems, facilities, services, people) that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy			CRI Profile v2.0: ID.AM CSF v1.1: ID.AM ISO/IEC 27001:2022: Mandatory Clause: None ISO/IEC 27001:2022: Annex A Controls: 5.9 ISO/IEC 27001:2022: Annex A Controls: 5.12 ISO/IEC 27001:2022: Annex A Controls: 5.13 NICE Framework: DD-WRL-001 NICE Framework: DD-WRL-002 NICE Framework: DD-WRL-003 NICE Framework: DD-WRL-004 NICE Framework: DD-WRL-005 NICE Framework: DD-WRL-009 NICE Framework: IO-WRL-001 NICE Framework: IO-WRL-002 NICE Framework: IO-WRL-003 NICE Framework: IO-WRL-004 NICE Framework: IO-WRL-005 NICE Framework: OG-WRL-011

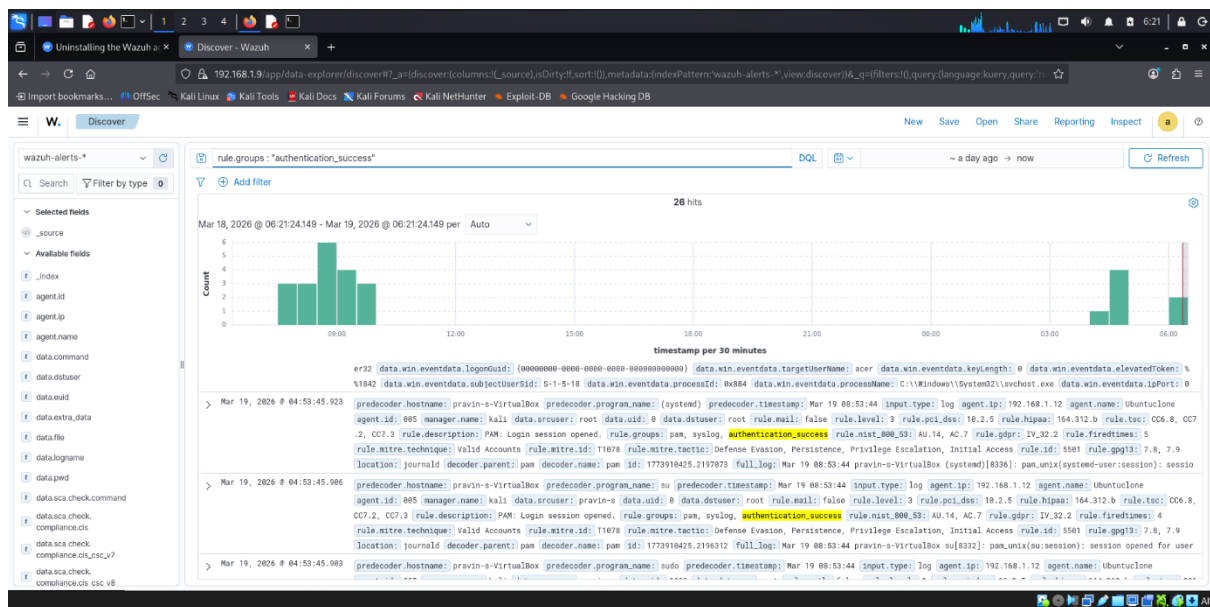


LOG Management:

We can view and filter the logs with Event Id like Failed Logon 4625 etc..

Also we can filter with KQL for “authentication_failure” , “authentication_successfull” etc.

Using wazuh dashboard we can use many filters to check specific logs on specific time.



WINDOWS Event Viewer:

It is the default log viewer for windows, we can view security logs, setup logs, system logs separately and also we can view application logs.



The screenshot shows the Windows Event Viewer application. The left pane displays the 'Security' log under 'Windows Logs'. The main pane shows a list of security events. The right pane shows the 'Actions' menu. A pop-up window titled 'Event Properties - Event 4624, Microsoft Windows security auditing.' is open, showing the 'General' tab. The 'Subject' field is 'Security ID:'. The 'Details' tab is also visible, showing the event description: 'An account was successfully logged on.' and the event details: 'The authentication information fields provide detailed information about this specific logon request. - Logon GUID is a unique identifier that can be used to correlate this event with a KDC event. - Transited services indicate which intermediate services have participated in this logon request.'

Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	19-03-2026 15:36:54	Microsoft Windo...	4672	Special Logon
Audit Success	19-03-2026 15:36:54	Microsoft Windo...	4624	Logon
Audit Success	19-03-2026 15:33:25	Microsoft Windo...	4672	Special Logon
Audit Success	19-03-2026 15:33:25	Microsoft Windo...	4624	Logon
Audit Success	19-03-2026 15:15:54	Microsoft Windo...	4672	Special Logon
Audit Success	19-03-2026 15:15:54	Microsoft Windo...	4624	Logon
Audit Success	19-03-2026 15:15:52	Microsoft Windo...	4798	User Account Ma...
Audit Success	19-03-2026 15:15:52	Microsoft Windo...	4798	User Account Ma...
Audit Success	19-03-2026 15:15:52	Microsoft Windo...	4798	User Account Ma...
Audit Success	19-03-2026 15:15:52	Microsoft Windo...	4798	User Account Ma...
Audit Success	19-03-2026 15:15:52	Microsoft Windo...	4798	User Account Ma...

The screenshot shows the Wazuh Discover interface. The search bar contains '4625'. The results show a single hit for the event ID 4625. The event details are displayed in a table format.

Field	Value
data.win.system.channel	Security
data.win.system.computer	214-59M
data.win.system.eventID	4625
data.win.system.eventRecordID	179171
data.win.system.keywords	8x8819888888888888
data.win.system.level	9
data.win.system.message	>
data.win.system.subject	An account failed to log on.
Subject	Security ID: S-1-5-21-2197475482-1186578435-447172123-1802
Account Name	acer



```
kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali ~
Session Actions Edit View Help
kali@kali ~
$ sudo apt install snort -y
[sudo] password for kali:
Upgrading:
  libhwloc-plugins libhwloc15 libze1 snort snort-common snort-common-libraries snort-rules-default

Summary:
Upgrading: 7, Installing: 0, Removing: 0, Not Upgrading: 1782
Download size: 3,110 kB / 4,091 kB
Space needed: 1,637 kB / 36.7 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 snort-common-libraries amd64 3.11.1.0-0kali1 [289 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 snort-rules-default all 3.11.1.0-0kali1 [231 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 snort amd64 3.11.1.0-0kali1 [2,462 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 snort-common all 3.11.1.0-0kali1 [128 kB]
Fetched 3,110 kB in 3s (1,033 kB/s)
Reading database ... 75%
```

```
GNU nano 8.6 /etc/snort/rules/local.rules
#Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures. Put your local
# additions here.
```




```
Session Actions Edit View Help
GNU nano 8.6 /etc/snort/rules/local.rules *
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures. Put your local
# additions here.

alert tcp any any -> any 80 (msg:"HTTP request to malicious.com detected";content:"Host:malicious.com";http_header;sid:1000001;rev:1;)
```

```
Session Actions Edit View Help
kali@kali: ~
GNU nano 8.6 /etc/snort.conf
--profiler = { }
--perf_monitor = { }

-- 5. configure detection

references = default_references
classifications = default_classifications

ips =
{
  -- use this to enable decoder and inspector alerts
  --enable_builtin_rules = true,

  -- use include for rules files; be sure to set your path
  -- note that rules files can include other rules files
  -- (see also related path vars at the top of snort_defaults.lua)

  variables = default_variables
  rules = [[include /etc/snort/rules/local.rules]]
}

-- use these to configure additional rule actions
-- react = { }
-- reject = { }

-- use this to enable payload injection utility
```

THE CIA TRIAD



The CIA Triad is a core framework in information security that helps organizations protect data and maintain secure, reliable systems.

Three principles: Confidentiality, Integrity, Availability

Guides policies for protecting sensitive information

Ensures data is secure, accurate, and accessible.

CIA Triad

Confidentiality:

Confidentiality ensures that sensitive data is accessible only to authorized individuals or systems. Its purpose is to prevent unauthorized viewing, access, or misuse of private information.

Risks to Confidentiality:

Unauthorized Access: Attackers exploit vulnerabilities to access protected data.

Weak Encryption: Outdated or weak encryption can be easily broken, exposing sensitive information.

Insider Threats: Employees or trusted users may leak or accidentally expose confidential data.

How to Ensure Confidentiality:

Encryption: Use strong encryption methods like AES or RSA to protect data from unauthorized reading, even if intercepted. (Note: DES is outdated and insecure.)

VPN: A Virtual Private Network creates an encrypted tunnel for internet communication, preventing eavesdropping or interception.

File



Confidentiality

Integrity:

Integrity ensures that data remains accurate, authentic, and unaltered during storage or transmission. Any unauthorized modification or corruption compromises the reliability of data.

Risks to Integrity:

Data Tampering: Attackers intentionally alter or corrupt data for malicious purposes.

Malware & Ransomware: Malicious software can modify, encrypt, or destroy data, leading to loss and system disruption.

How Integrity Is Ensured

To detect whether data has been modified, hash functions are used. Common Hash Functions:

MD5: Produces a 128-bit hash value.

SHA Family: Includes SHA-1 (160-bit), SHA-0, SHA-2, and SHA-3.

Working of Hash Functions

1. Host A Sends Data: Host A creates a hash value (H1) using a hash function.
2. Attach Hash: H1 is sent along with the data.
3. Host B Verifies: Host B generates a new hash (H2) from the received data.

4. Compare:

If $H1 = H2$, the data is unchanged (integrity preserved).



If $H1 \neq H2$, the data was altered or corrupted.

Even a tiny change in the input completely changes the output hash.

file

Hash Function

Note: Even a small change in the input (like altering a single word or character) will completely change the resulting hash."

Availability:

Availability ensures that systems, networks, and data are accessible to authorized users whenever needed. Disruptions can halt operations and cause major losses.

Risks to Availability:

DoS and DDoS Attacks: Denial of Service (DoS) or Distributed Denial of Service (DDoS) attacks flood network resources with excessive traffic, making them unavailable to legitimate users.

Impact: Such attacks can cause major service disruptions, downtime, and financial losses for companies.

How to Ensure Availability:

To ensure availability, network administrators should focus on the following factors:

Hardware Maintenance: Regularly maintain and upgrade hardware to prevent failures and ensure smooth operations.

Regular Upgrades: Keep systems and software updated to maintain performance and security.

Failover Plan: Implement failover systems so that if one component fails, another can take over, minimizing downtime.

Preventing Bottlenecks: Monitor and manage network traffic to avoid congestion or bottlenecks, ensuring consistent performance.



Key Learnings :

Built foundational knowledge on SOC fundamentals and tools by setting up Wazuh SIEM and Elastic SIEM, snort and Nessus and also accessing Event Manager On windows vm.